

Information Security

Unit- 5 Access Control

Access Control

- Access control is a fundamental aspect of computer security, essential for regulating access to information and system resources.
- It encompasses the processes and policies that determine who can access specific data and resources and under what conditions.
- Here are two authoritative definitions that help outline the scope of access control:

1. NIST IR 7298 (Glossary of Key Information Security Terms):

- Access control is the process of granting or denying specific requests to:
 1. Obtain and use information and related information processing services.
 2. Enter specific physical facilities.

2. RFC 4949 (Internet Security Glossary) :

- Access control is a process by which the use of system resources is regulated according to a security policy and is permitted only by authorized entities (users, programs, processes, or other systems) according to that policy.
- The principal objectives of computer security are to prevent unauthorized users from gaining access to resources, to prevent legitimate users from accessing resources in an unauthorized manner, and to enable legitimate users to access resources in an authorized manner.

Principles of Access Control

- Access control is the foundation of computer security, ensuring that only authorized entities can access specific system resources according to defined policies. The principles of access control are grounded in the concepts of authentication, authorization, and auditing, forming a comprehensive framework for regulating access. Here are the key principles:

1. Authentication :

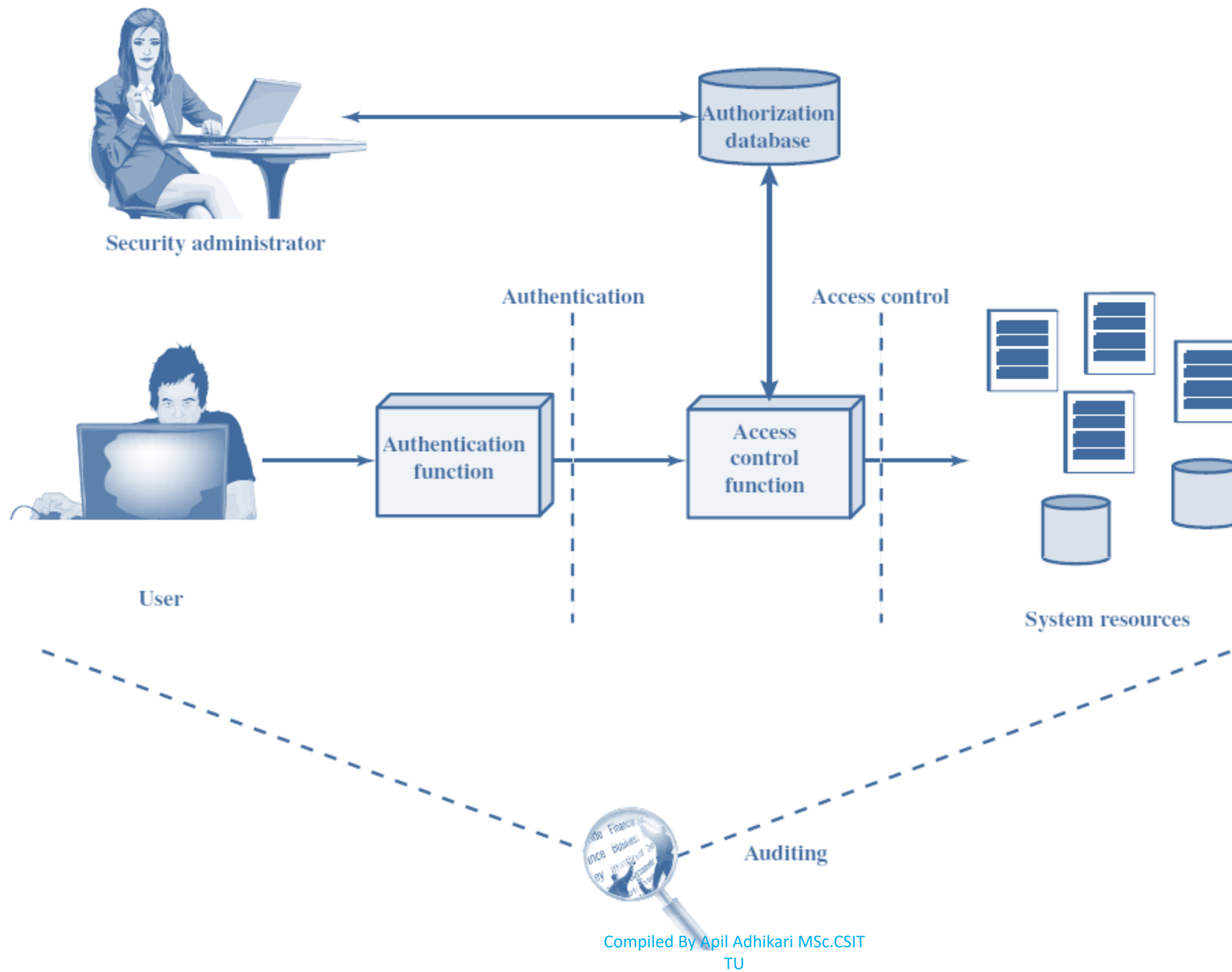
- Verification that the credentials of a user or other system entity are valid.

2. Authorization :

- The granting of a right or permission to a system entity to access a system resource. This function determines who is trusted for a given purpose.

3. Audit :

- An independent review and examination of system records and activities in order to test for adequacy of system controls, to ensure compliance with established policy and operational procedures, to detect breaches in security, and to recommend any indicated changes in control, policy and procedures.



- An access control mechanism mediates between a user (or a process executing on behalf of a user) and system resources, such as applications, operating systems, firewalls, routers, files, and databases.
- The system must first authenticate an entity seeking access. Typically, the authentication function determines whether the user is permitted to access the system at all.
- Then the access control function determines if the specific requested access by this user is permitted.
- A security administrator maintains an authorization database that specifies what type of access to which resources is allowed for this user. The access control function consults this database to determine whether to grant access.
- An auditing function monitors and keeps a record of user accesses to system resources.

Access Control Policies

- Access control policies determine who can access what resources and under what conditions. Here are the main types of access control policies:
 1. **Discretionary access control (DAC):** Controls access based on the identity of the requestor and on access rules (authorizations) stating what requestors are (or are not) allowed to do. This policy is termed discretionary because an entity might have access rights that permit the entity, by its own volition, to enable another entity to access some resource.
 2. **Mandatory access control (MAC):** Controls access based on comparing security labels (which indicate how sensitive or critical system resources are) with security clearances (which indicate system entities are eligible to access certain resources). This policy is termed mandatory because an entity that has clearance to access a resource may not, just by its own volition, enable another entity to access that resource.
 3. **Role-based access control (RBAC):** Controls access based on the roles that users have within the system and on rules stating what accesses are allowed to users in given roles.

Access Control Policies

4. **Attribute-based access control (ABAC):** Controls access based on attributes of the user, the resource to be accessed, and current environmental conditions.

Subject Object and Access Rights

➤ Access control involves three basic elements: subject, object, and access rights.

1. **Subject:** An entity capable of accessing objects, typically a process that represents a user or application.

Types:

1. **Owner:** Creator or responsible entity for a resource, like a file or system resource.
 2. **Group:** A named group of users with shared access rights.
 3. **World:** Users with the least access, not included in owner or group categories.
-
2. **Object:** A resource that requires access control, used to contain or receive information.
Examples: Files, records, directories, mailboxes, messages, programs, and more.

Subject Object and Access Rights

3. Access Rights: Specifies how a subject can interact with an object.

Types:

- i. **Read:** View, copy, or print information.
- ii. **Write:** Add, modify, or delete data.
- iii. **Execute:** Run programs.
- iv. **Delete:** Remove resources.
- v. **Create:** Make new files or records.
- vi. **Search:** List or search directory contents.

Access Control Matrix (ACM)

- It is a table that defines access permissions between specified subjects and objects.
- Rows of ACM corresponds to users /subjects/groups.
- Columns corresponds to resources that need to be protected.
- $ACM[U,O]$ defines what access rights user U has for object O .
- It is also called Lampson's access control matrix.
- Consider a system with three users (Alice, Bob, and Carol) and three files (file1, file2, file3). The access rights are defined as follows:
 - Alice can read and write file1 and file2 but has no access to file3.
 - Bob can read file1 and file3 but has no access to file2.
 - Carol can write to file2 and read file3 but has no access to file1.

The access control matrix for this scenario would look like this:

	file1	file2	file3
Alice	read, write	read, write	-
Bob	read	-	read
Carol	-	write	read

Access Control List(ACL)

- An Access Control List (ACL) is a list of permissions attached to an object specifying which subjects (users or processes) can access the object and what operations they can perform on it.
- Each entry in an ACL identifies a subject and the operations that the subject is allowed or denied to perform on the object.
- Consider a file system with three files (file1, file2, file3) and three users (Alice, Bob, Carol). The ACLs for these files might look like this:

1. file1 ACL:

Alice: read, write

Bob: read

Carol: no access

2. file2 ACL:

Alice: read, write

Bob: no access

Carol: write

3. file3 ACL:

Alice: no access

Bob: read

Carol: read

Advantages of ACL

- ACLs allow for detailed specification of permissions for each object, giving precise control over access.
- Different subjects can have different permissions for the same object, making it easy to customize access.
- ACLs can be easily modified to add, change, or remove permissions for specific subjects.

Disadvantages of ACL

- Managing ACLs can become complex in systems with many objects and subjects, potentially leading to a large number of ACL entries.
- Checking permissions in ACLs can be time-consuming, especially if the ACL is long or needs to be checked frequently.
- Ensuring consistency of ACLs across different systems or components can be challenging.

Capability List(CL)

- A capability list is an access control mechanism used in computer systems to manage the access rights of subjects (such as users or processes) to objects (such as files, directories, or devices). Unlike Access Control Lists (ACLs), which are attached to objects and list the subjects and their permissions, capability lists are associated with subjects and specify the objects and the permissions those subjects have.
- Consider a system with three users (Alice, Bob, Carol) and three files (file1, file2, file3). The capability lists for these users might look like this:

1. Alice's Capability List:

file1: read, write
file2: read, write
file3: no access

2. Bob's Capability List:

file1: read
file2: no access
file3: read

3. Carol's Capability List:

file1: no access
file2: write
file3: read

Advantages of CL

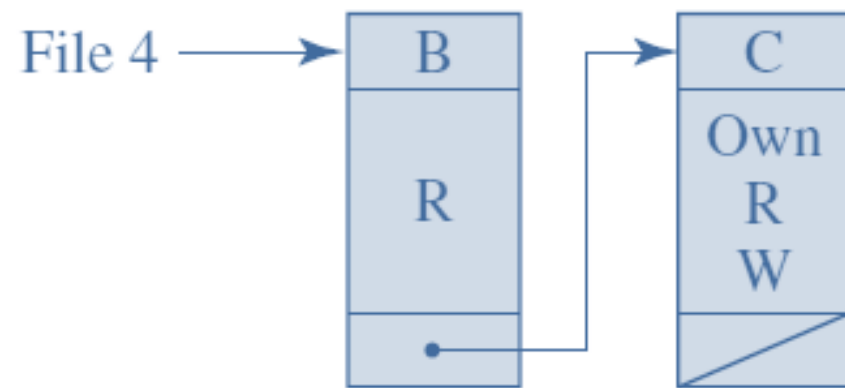
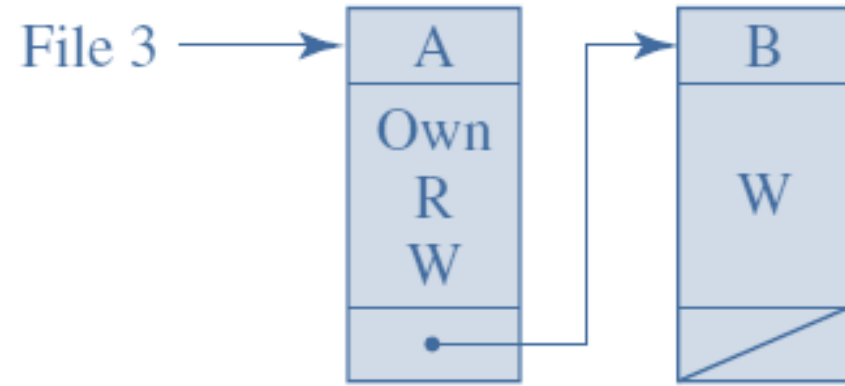
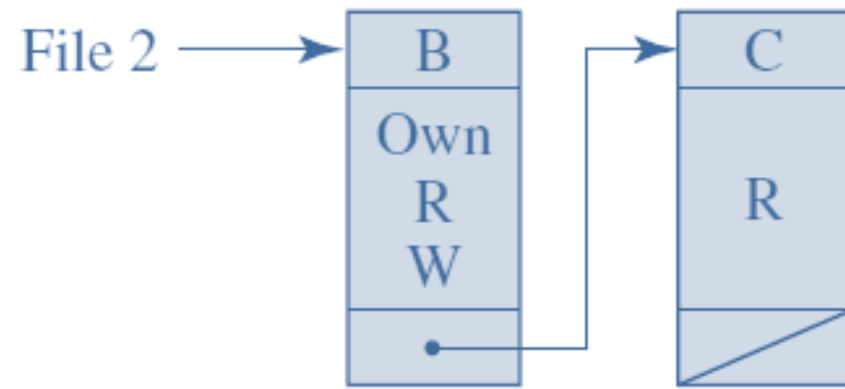
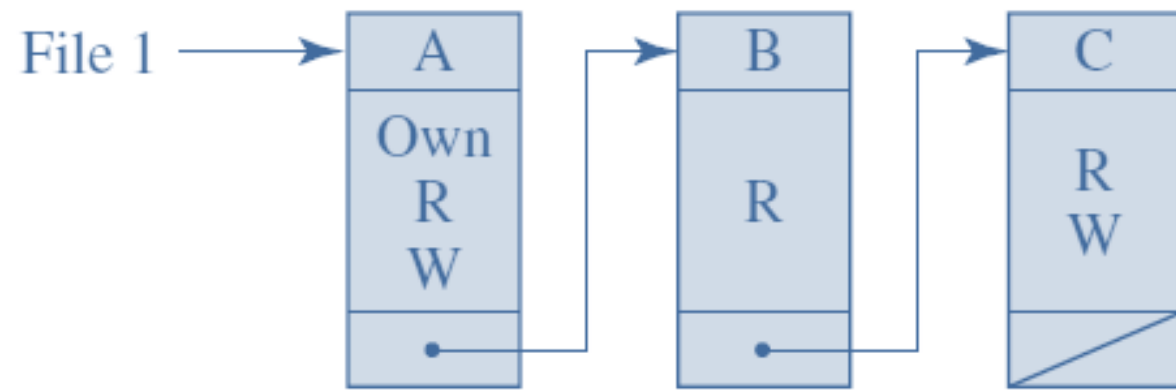
- It is easy to determine what resources a particular subject can access.
- Subjects can possess and manage their own capabilities, potentially reducing the need for central administration.
- Capabilities can be implemented as unforgeable tokens, ensuring that subjects cannot gain unauthorized access by tampering with their capabilities.

Disadvantages of CL

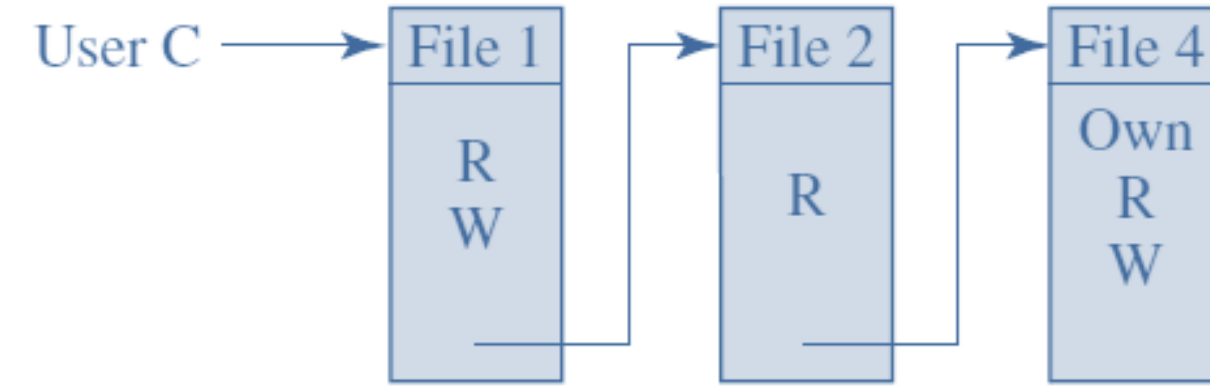
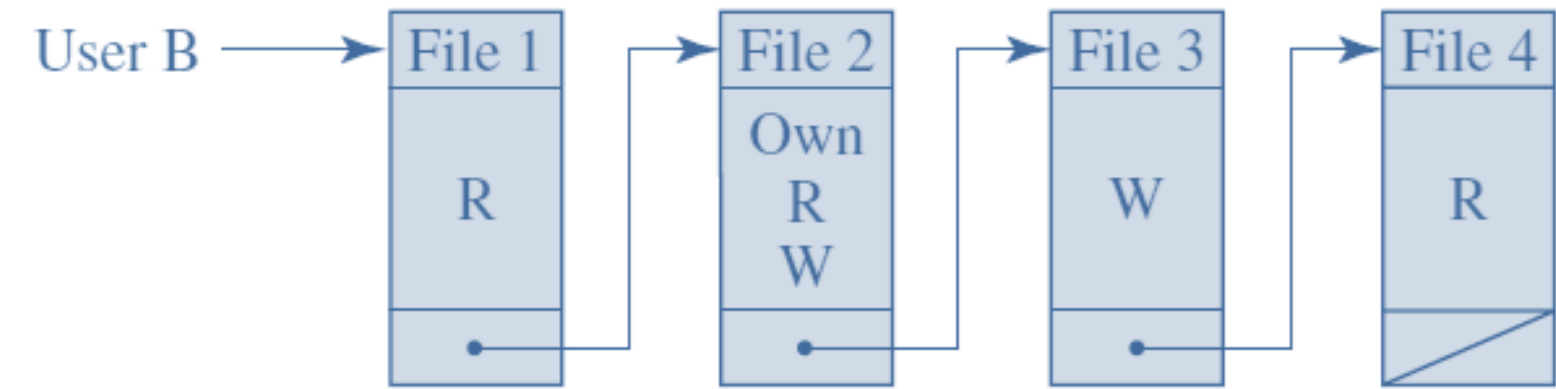
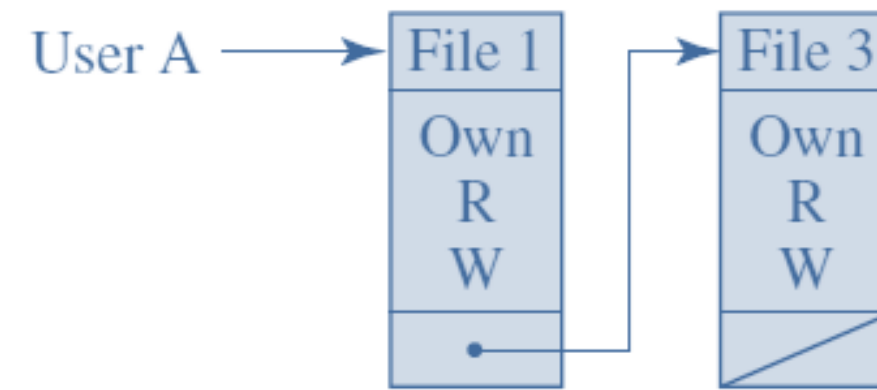
- Revoking access can be complex, especially if capabilities are distributed and need to be invalidated.
- Managing capabilities for a large number of subjects and objects can become complex.
- Ensuring that capabilities are not improperly shared or duplicated requires careful management.

		OBJECTS			
		File 1	File 2	File 3	File 4
SUBJECTS	User A	Own Read Write		Own Read Write	
	User B	Read	Own Read Write	Write	Read
	User C	Read Write	Read		Own Read Write

(a) Access matrix



(b) Access control lists for files of part (a)



(c) Capability lists for files of part (a)

Authorization Table

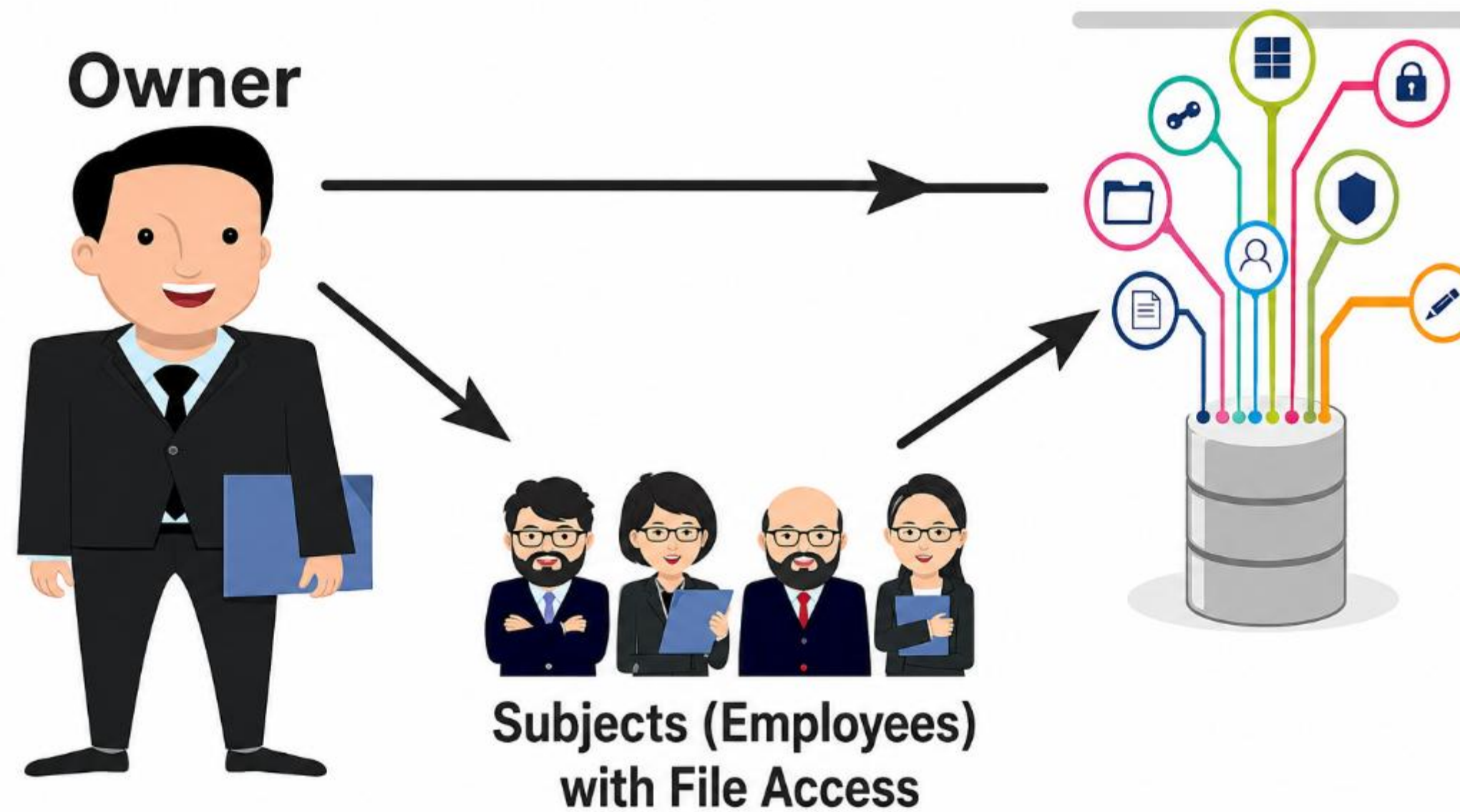
- An authorization table is a more flexible and dynamic approach that combines the strengths of both ACLs and Capability Lists. It can be visualized as a table with rows indicating a specific access right of a subject to an object. This table can be sorted or accessed by subjects or objects as needed.
- For the above example, an authorization table might look like this:

Subject	Object	Access Right
Alice	file1	read
Alice	file1	write
Alice	file2	read
Alice	file2	write
Bob	file1	read
Bob	file3	read
Carol	file2	write
Carol	file3	read

Discretionary Access Control (DAC)

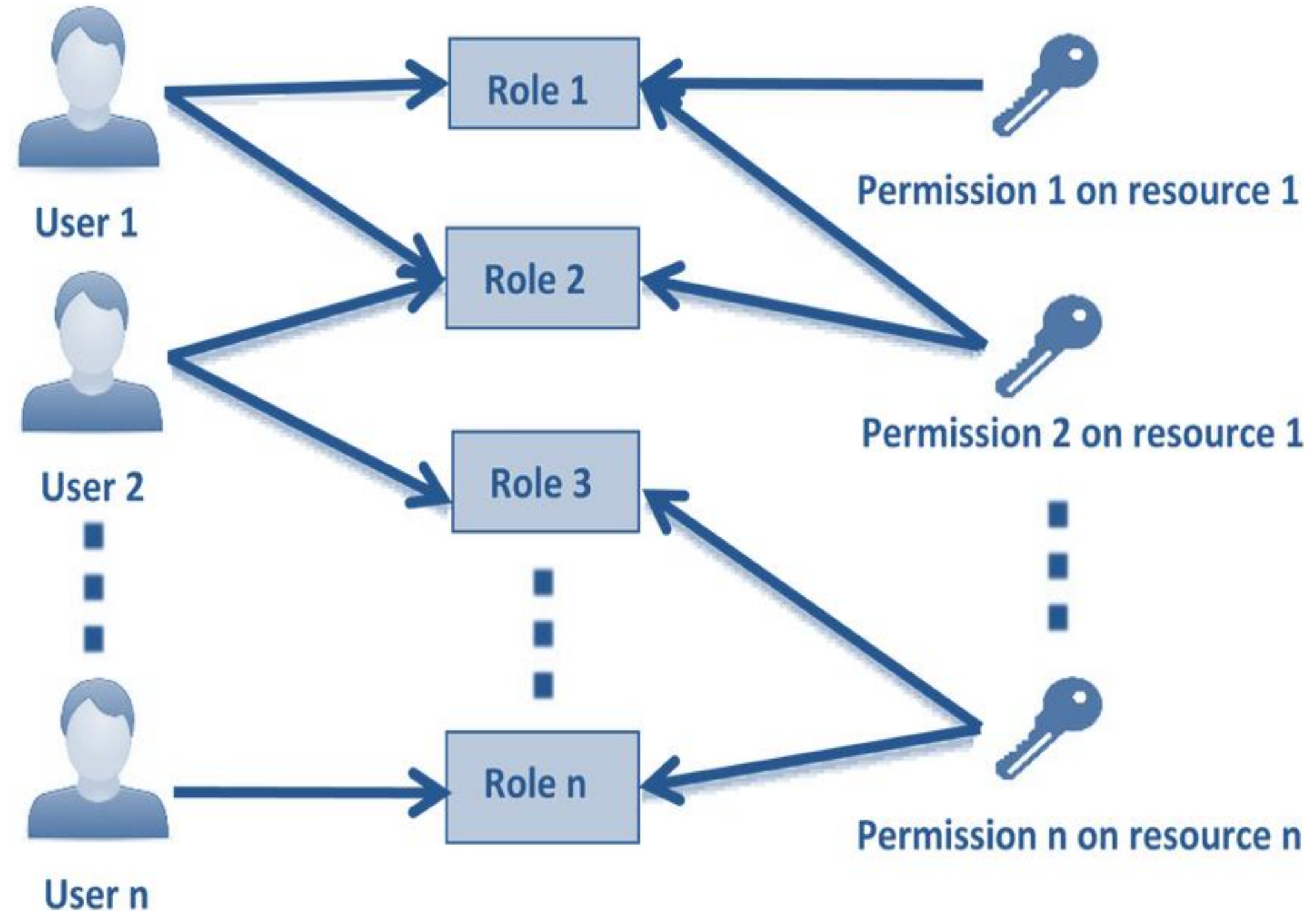
- Discretionary Access Control (DAC) is a type of access control mechanism where the access rights to resources are determined by the resource owner or administrator. In DAC systems, users have the flexibility to decide who can access their resources and what operations those users can perform.
- When a user creates a resource (e.g., a file), they become the owner of that resource.
- The owner can specify which other users or groups can access the resource and what actions they are allowed to perform.
- DAC systems often use ACMs or ACLs to manage permissions. Each resource has an ACM or ACL that lists the users and their respective access rights.
- When a user attempts to access a resource, the system checks the ACM or ACL to determine if the access should be granted or denied based on the permissions set by the owner.

Discretionary Access Control (DAC)



Role Based Access Control (RBAC)

- Role-Based Access Control (RBAC) is a widely used access control mechanism that restricts system access to authorized users based on their roles within an organization. Instead of assigning permissions directly to individual users, RBAC assigns permissions to roles, and then users are assigned to these roles. This approach simplifies the management of permissions, especially in large organizations.



Role Based Access Control (RBAC)

- Role-Based Access Control (RBAC) can be effectively depicted and implemented using an access matrix representation, which helps in visualizing and managing the relationships between users, roles, and resources (objects).
- The access matrix consists of two parts: one that maps users to roles and another that maps roles to permissions on resources.

1. User-to-Role Matrix (Upper Matrix):

- This matrix maps individual users to roles. The rows represent users, and the columns represent roles. An entry in the matrix is marked (e.g., with an "X") if a user is assigned to a particular role. This matrix highlights which users have been assigned which roles.

2. Role-to-Permission Matrix (Lower Matrix):

- This matrix maps roles to permissions on resources (objects). The rows represent roles, and the columns represent resources. Each entry in this matrix specifies the permissions (e.g., read, write, execute) that a role has on a particular resource.

Role Based Access Control (RBAC)

U\R	R1	R2	...	Rn
U1	X			
U2	X	X		
U3		X		
U4				X
U5	X			X
U6				X
Um		X		X

Roles	F1	F2	D1	D2	...
R1	read	write	execute		
R2	write	execute		read	
...					
Rn	owner	read	write	control	

Attribute Based Access Control (ABAC)

- Attribute based access control also known as policy-based access control (PBAC) or claim-based access control (CBAC), is an authorization methodology that sets and enforces policy based on characteristics, such as department, location, manager, and time of day.
- It uses Boolean logic with if-then statements that defines user, request, resources and action. For example, If the requester is sales person, they are granted read-write access to CRM solution as opposed to administrator who is only granted view privileges to create a report.
- **Uses :**
 1. Protecting data, network devices, cloud services and IT resources from unauthorized user or action.
 2. Securing microservices/ application programming interfaces(APIs) to prevent expose of sensitive transactions.
 3. Enabling dynamic network firewall controls by allowing policy decisions to be made on a per-user basis.

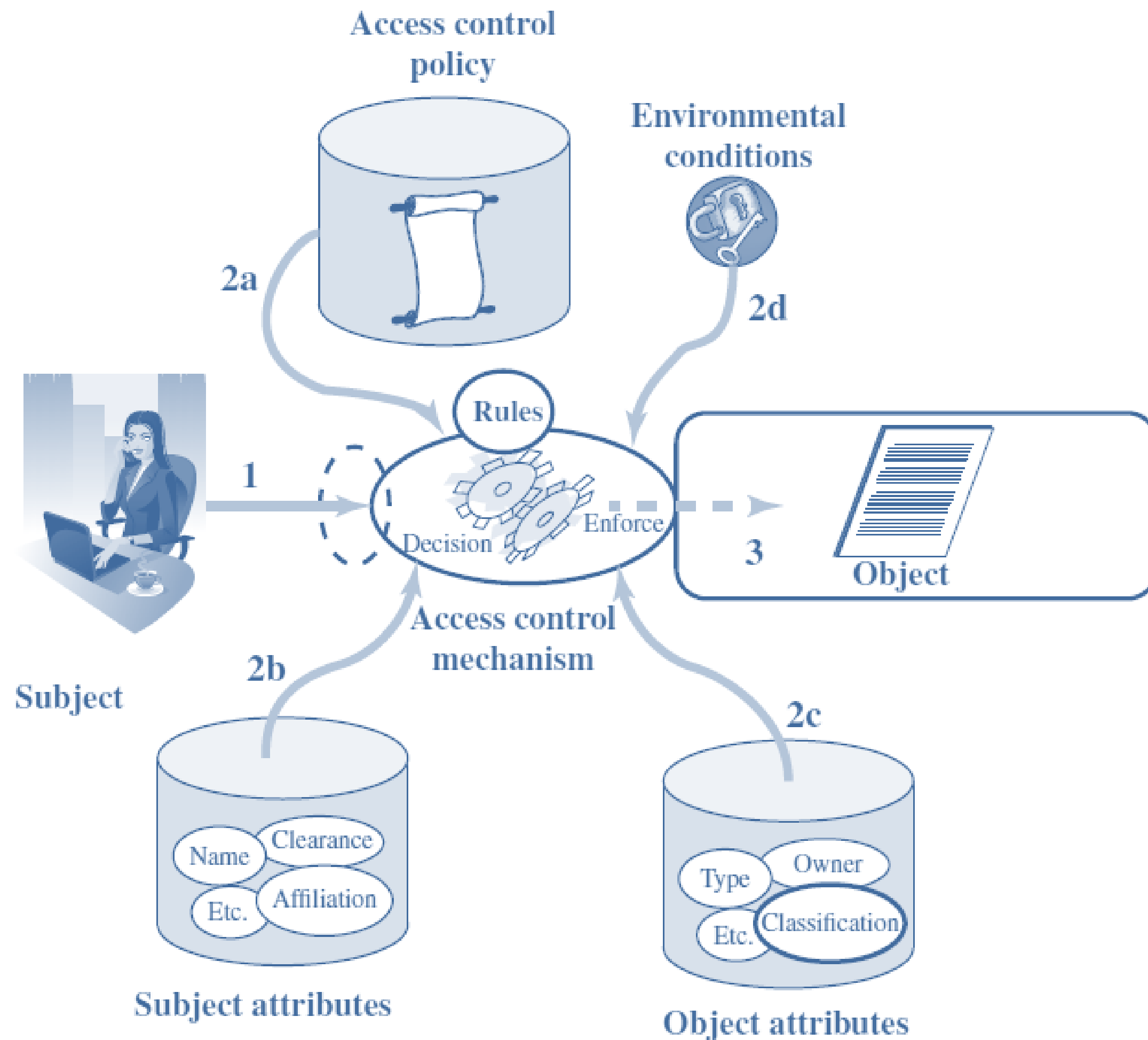
Components of ABAC

1. **Attributes:** Characteristics or properties of entities in the system. Attributes are classified into several types.

Types:

1. **User Attributes:** Characteristics of the user, such as role, department, clearance level, location, etc.
 2. **Resource Attributes:** Characteristics of the resource or object, such as type, sensitivity level, owner, creation date, etc.
 3. **Environment Attributes:** Contextual information, such as time of day, location, IP address, etc.
-
2. **Policies :** Policies are the rules that define how attributes are used to grant or deny access. Policies are usually written in a formal language and specify conditions under which access is permitted or denied.

3. **Request** : When a user attempts to access a resource, an access request is generated, including the user's attributes, the resource's attributes, and the current environmental conditions.
4. **Policy Decision Point(PDP)** : The component that evaluates access requests against policies to make access decisions (grant or deny).



Identity, Credential and Access Management

- Identity, Credential, and Access Management (ICAM) is a comprehensive framework used to manage digital identities, credentials, and access control.
- It encompasses various components aimed at ensuring secure and efficient management of identity and access within organizations, including government agencies and enterprises.
- It reduces the risk of cyber attack to the organization by preventing unauthorized access to the network, system and data.

Key Components of ICAM

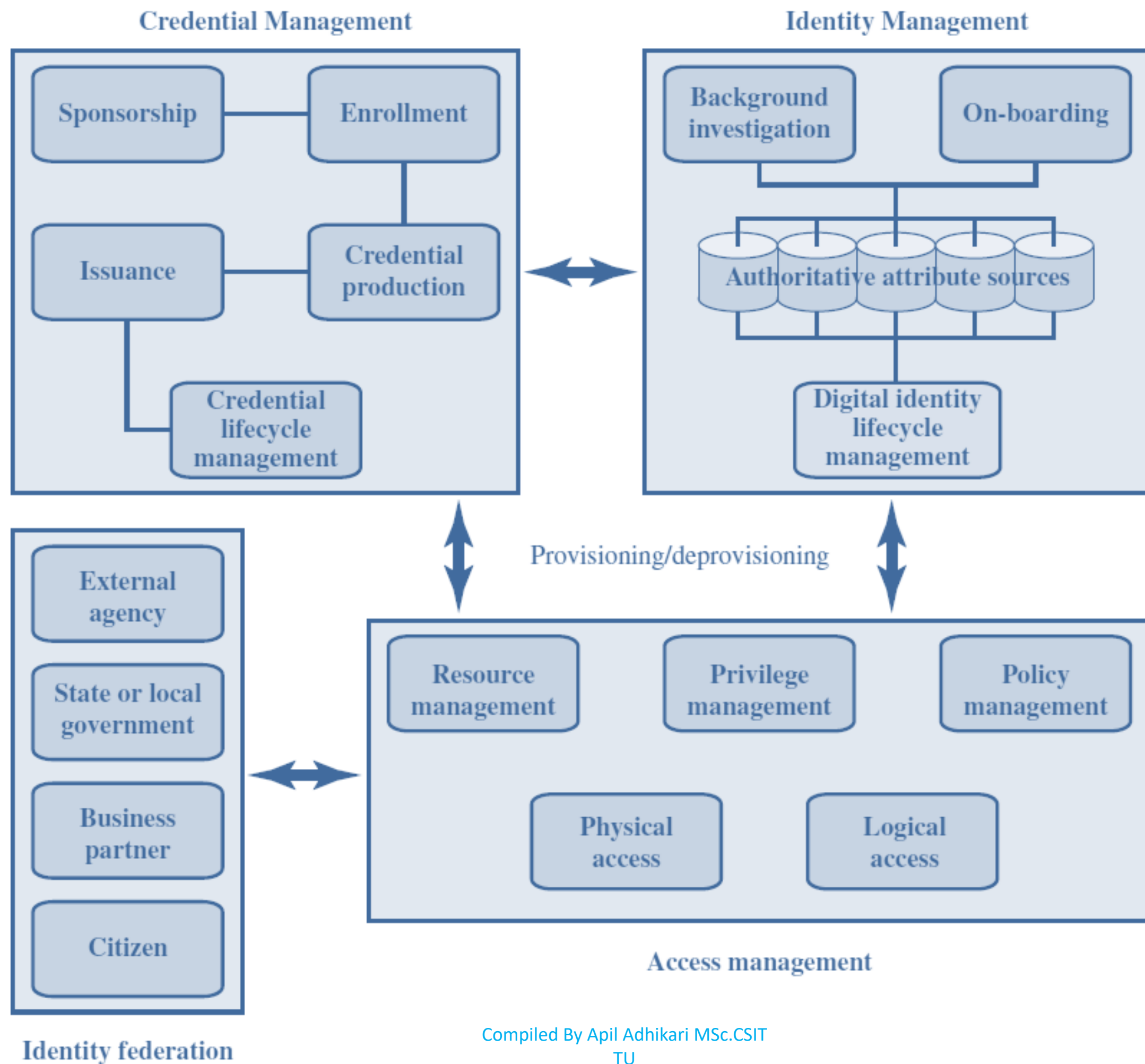
1. **Identity Management** : Identifies a subject and establishes that are who they claim to be when authorizing access to a system.
 1. **Digital Identity creation**: Assigns attributes to digital identities, linking them to individuals or nonperson entities (NPEs) such as processes, applications, and automated devices.
 2. **On-boarding and Lifecycle Management**: Involves collecting identity data during on-boarding, conducting background checks, and managing digital identity throughout its lifecycle, including updates and de-provisioning when access is no longer needed.
 3. **Enterprise Identity Record**: Contextual information, such as time of day, location, IP address, etc.

2. Credential Management :

- Binds the identity of authenticator, allowing the system to identify the user through login(i.e. user authentication, identification card, username and password).
- Encompasses credential sponsorship, enrollment(including identity proofing and biometric data capture), production, issuance, and maintenance, including tasks like revocation, reissuance, and expiration management.

3. Access Management:

- Grants permissions for what users can do and see within a system (e.g. using specific groups and role for separation).
- Access management determines which roles or users can access different information and processes at specific times and levels of security(i.e. restrict access to a database unless the user is authenticated and is in a role that has been granted access to that resource).



Trust Framework

- A Trust Framework is a set of policies, technologies, and practices that establish the parameters for trust within and across organizations, especially in digital transactions and interactions.
- It ensures that parties involved in a transaction or access control scenario can reliably ascertain the identity and attributes of each other, thereby facilitating secure and efficient operations.
- Trust framework includes following components

1. Trust :

- Trust in this context refers to the confidence that one entity (individual or organization) can have in another's identity, attributes, and the authenticity of their credentials.
- Trust is established through a combination of legal, technical, and operational measures that verify and validate the identity and attributes of entities involved in a transaction.

2. Identity :

- This is a set of attributes and information that uniquely identifies an individual or non-person entity (NPE) within a given context.
- Digital identities are managed and authenticated through identity management systems.
- The process of verifying an identity involves confirming that the presented credentials (such as a staff ID, security clearance, or professional license) genuinely belong to the individual or NPE claiming them.

3. Attributes:

- Attributes are specific pieces of information associated with an identity, such as a professional registration number, department, security clearance, or credit card number.
- The required attributes for a transaction or access control decision depend on the context.
- For instance, a customer reference number might be needed for a purchase, while a security clearance might be required for access to a restricted area.

4. Contextual Access Control:

- **Need-to-Know Principle:** This principle dictates that only the necessary attributes required for a particular transaction or access should be disclosed and verified, protecting privacy and maintaining efficiency.
- Access decisions are based not only on identity but also on the attributes of the requestor and the resource, ensuring that access is granted appropriately based on context-specific criteria.

Application of Trust Frameworks

1. E-commerce:

- Verification of attributes like credit card numbers, shipping addresses, and customer reference numbers to facilitate secure and trusted transactions.
- Ensuring that only necessary information is shared and verified, maintaining user privacy and complying with legal requirements.

2. Enterprise Access Control:

- Granting access to resources based on verified attributes such as staff ID, security clearance, or professional credentials.
- Managing access for external entities like suppliers and partners based on relevant attributes, ensuring secure collaboration.

3. Healthcare:

- Verification of attributes such as unique health identifiers, allergies, and blood type for secure and accurate medical treatment.
- Ensuring that only authorized individuals with verified attributes can access sensitive health information.

!!!Thank you!!!